Lab Assignment 7

Stepan Shkrobak

Dr. Michael Bartolacci

IST 894, Section 001: Capstone Experience,

8 March 2026

Table of Contents

Table of Contents....2
General Context....2
Technical Context....4
Screenshots....6
References....22

General Context

The Web Vulnerabilities lab focused on identifying common web application vulnerabilities that are created when applications fail to properly validate or sanitize user

input. The lab showed how attackers can manipulate web applications using techniques such as cross site scripting, SQL injection, directory traversal, and file inclusion. These vulnerabilities are created when an input provided by the user is processed by an application without proper filtering or security checks. For example, malicious input may be read in as executable code within a webpage or as part of a database query. This allows attackers to manipulate the application in an unintended way and access potentially sensitive information.

The lab also covered the potential impact that these vulnerabilities can have on real-world systems and organizations. According to the Open Web Application Security Project (OWASP), injection attacks and improper input validation continue to rank among the most critical security risks affecting modern web applications (OWASP, 2023). Stored cross-site scripting vulnerabilities, for example, can allow malicious scripts to remain embedded within a website and execute whenever other users access the affected content. SQL injection attacks allow attackers to manipulate database queries to retrieve or alter sensitive information stored on backend systems, potentially even allowing attackers to fully delete all the data. Then there are directory traversal and file inclusion vulnerabilities, which further show how attackers may bypass application restrictions to access files outside the intended web directory or force the application to load files from the server.

The Secure and Insecure Protocols lab focused on network security by looking at how network traffic can be captured and analyzed using packet sniffing tools. Looking at how data travels across networks in packets and how these packets can be inspected allowed a better understanding of the behavior of different communication protocols. For

example, using FTP and then more secure options like SSH and SFTP. Unencrypted protocols transmitted login credentials and file contents in clear text, meaning anyone who intercepted the network traffic could read the information. The encrypted protocols, on the other hand, used encryption algorithms and key exchange processes to secure the data.

Technical Context

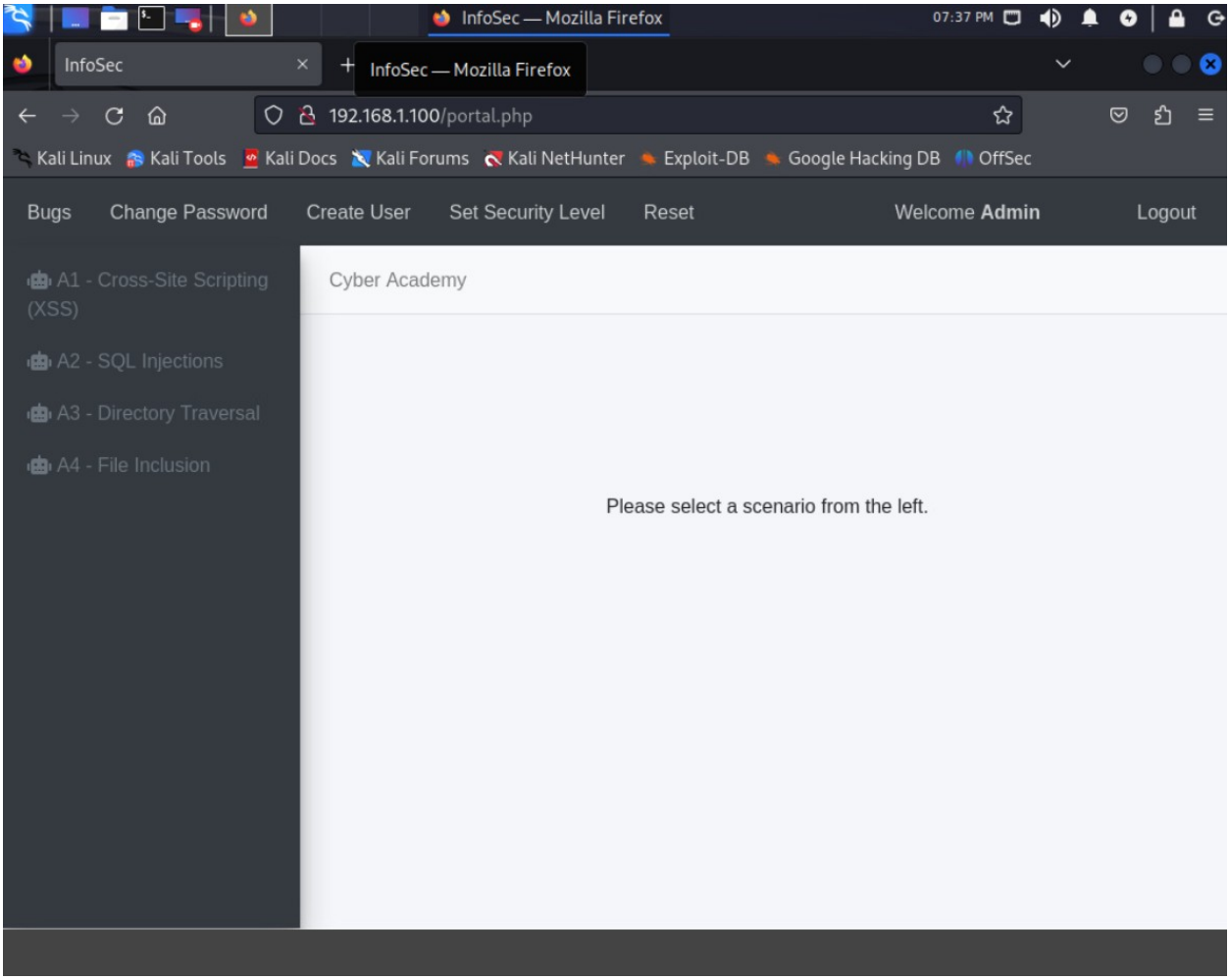
The Web Vulnerabilities lab covered how common web application security flaws are created when applications fail to properly validate or sanitize user input. Reflected and store cross site scripting attacks, for example, were performed where unsanitized inputs were executed, allowing attacker-supplied HTML or JavaScript to be executed within the victim's session context. An example of this was the insertion of HTML tags like <b> or JavaScript payloads like <script>alert('XSS')</script> into application input fields, which resulted in the code being rendered by the browser, showing that the application was vulnerable. Also, there was some DOM-based cross-site scripting, where client-side JavaScript retrieved user-controlled parameters from a GET request and inserted them into the page using unsafe DOM sinks such as innerHTML().

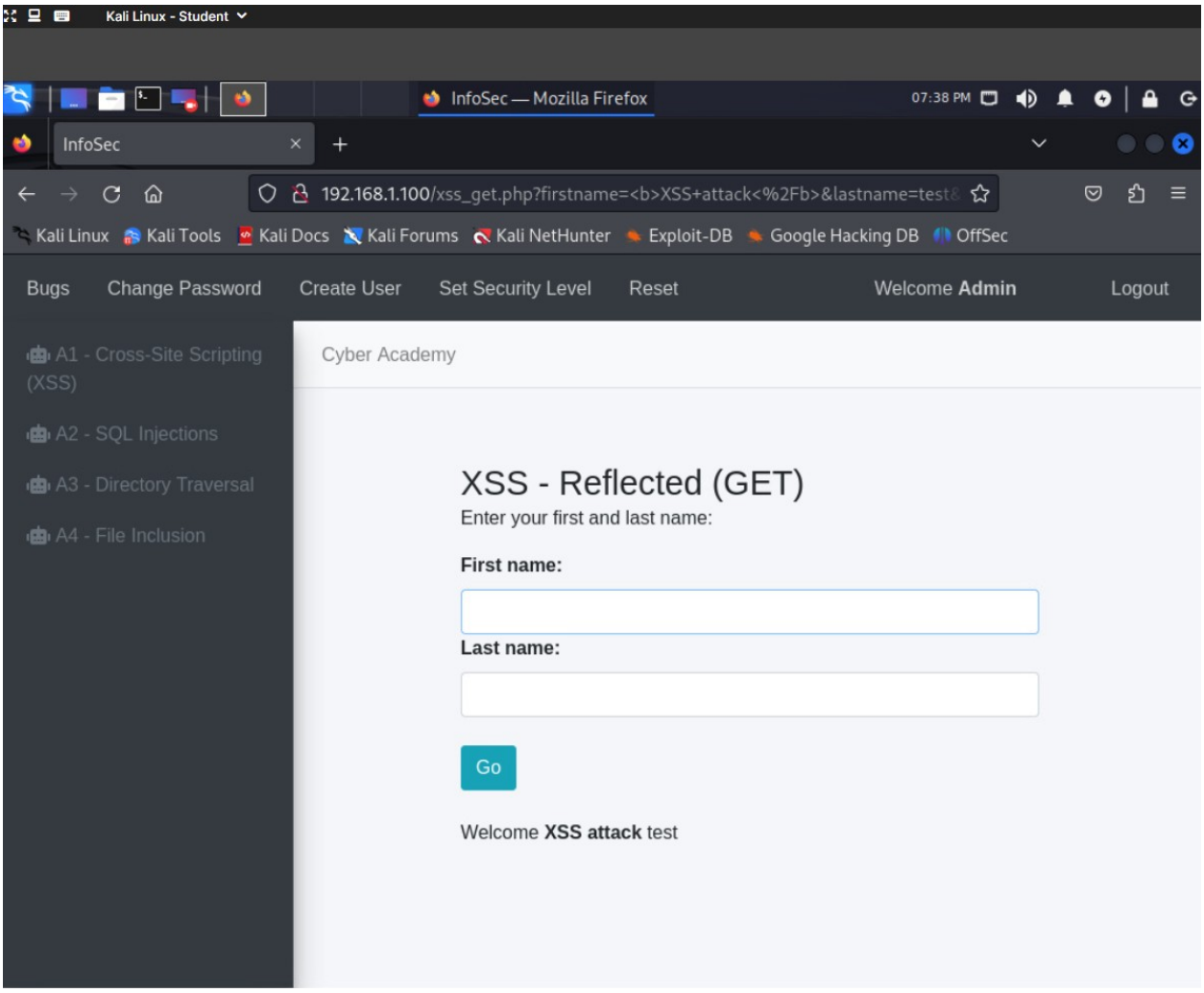
In the lab, some server-side injection vulnerabilities were also seen. According to the National Institute of Standards and Technology (NIST), injection attacks and improper input validation are significant web application security risks because they allow attackers to manipulate application inputs in ways that can expose sensitive data or alter system behavior (NIST, 2022). In a SQL injection, for example, a single quote disrupted the backend query logic, resulting in database errors that revealed the query

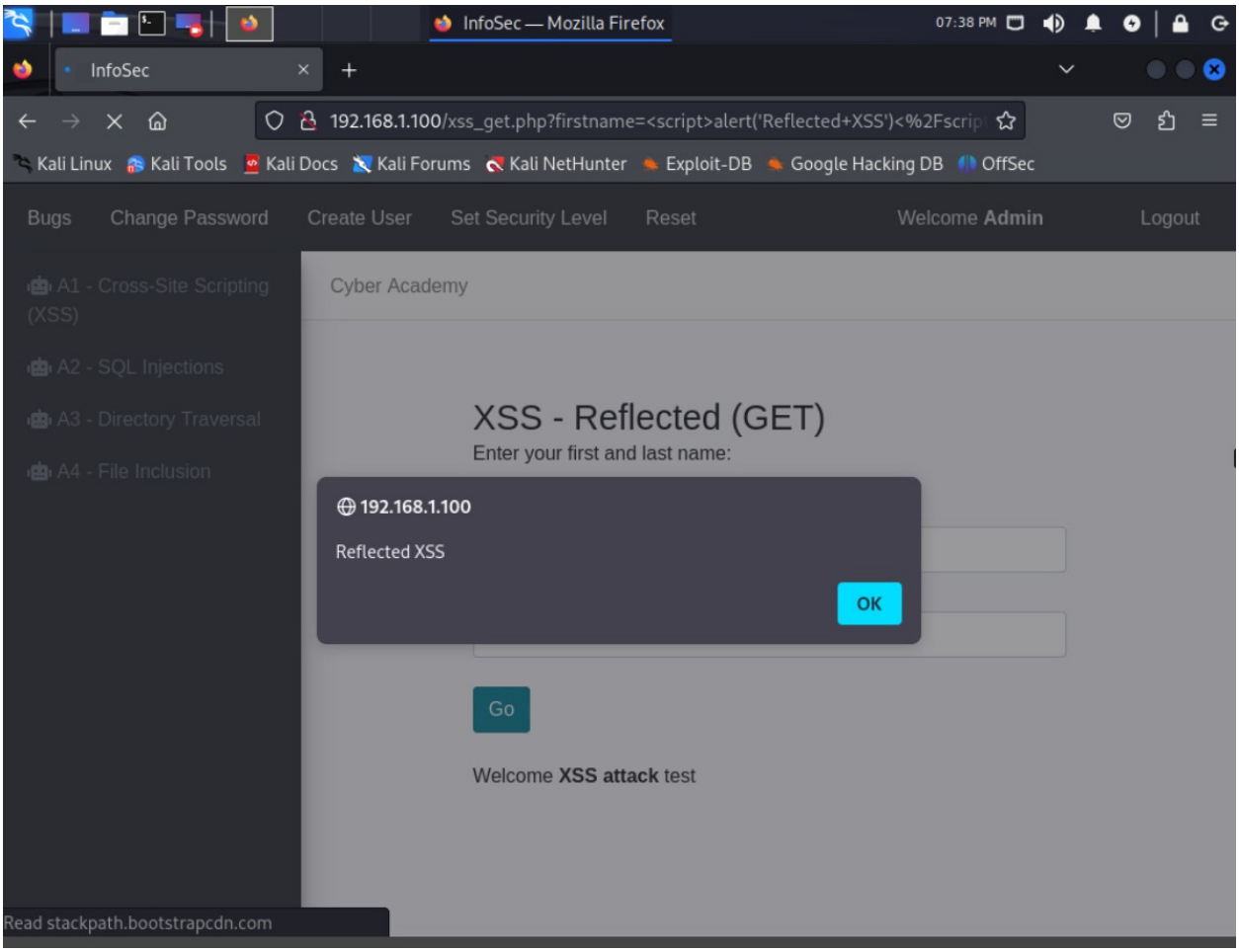
structure. With such a vulnerability, payloads such as ' OR 1=1-- could manipulate conditional logic within the SQL statement, causing the application to return all records from the database table. The lab also showed insecure file handling issues such as directory traversal and local file inclusion, where user-controlled path parameters allowed navigation outside of the intended web root directory using relative path sequences such as ../../../../, allowing access to sensitive system files, including /etc/passwd.

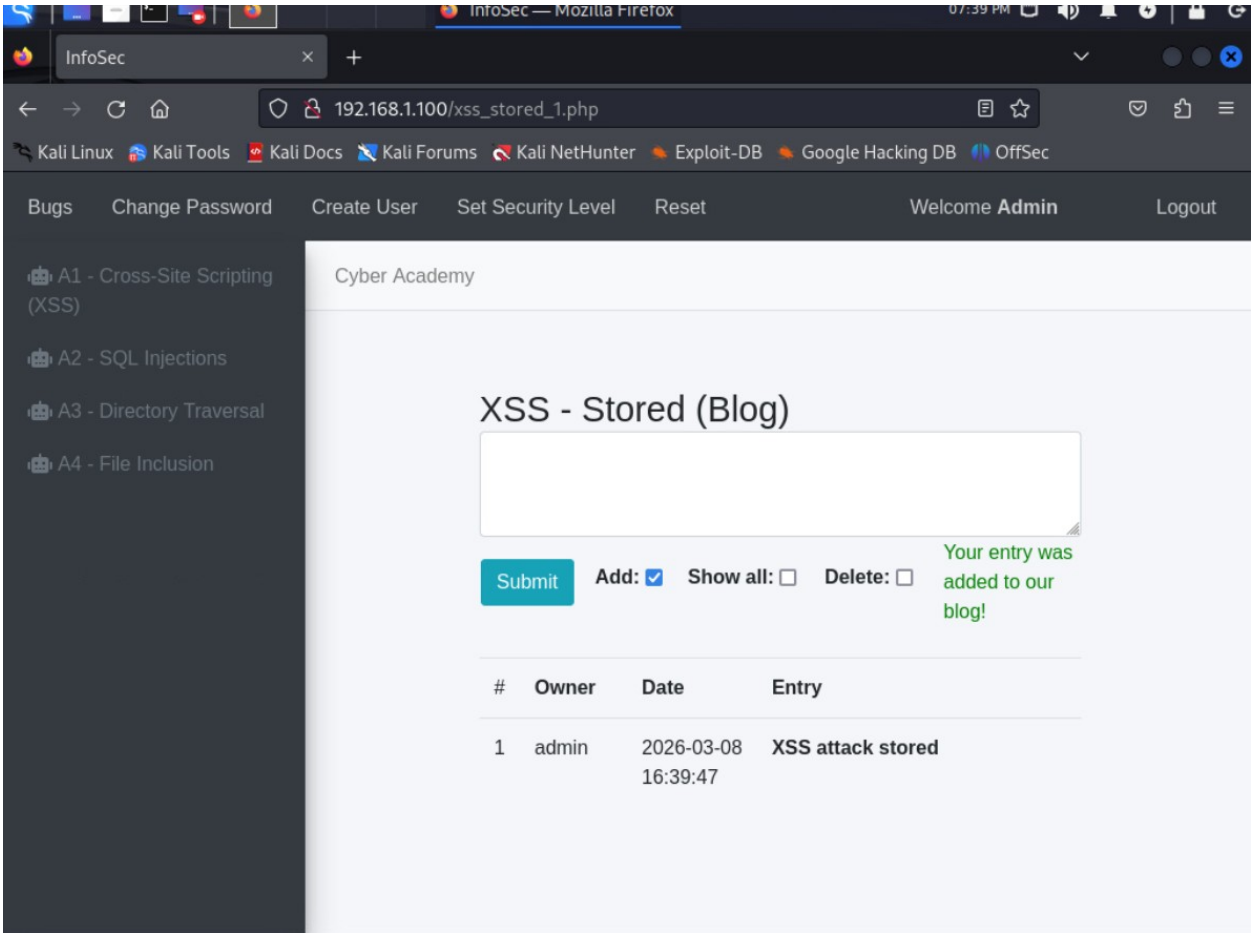
The Secure and Insecure Protocols lab focused on network-level security by looking at how packet captures can be used to analyze traffic and identify insecure communication protocols. According to the National Institute of Standards and Technology (NIST), encryption and secure authentication mechanisms are essential for protecting the confidentiality and integrity of information transmitted across networks (NIST, 2023). Using Wireshark and tcpdump, for example, packet captures were done on several traffic created by different protocols to see how authentication and file transfer data are transmitted across a network. When looking at FTP traffic, the captured packets revealed authentication credentials and file contents while transmitted in clear text across the network. FTP login commands also exposed the username and password directly within packet payloads, while SSH and SFTP sessions showed encrypted communication following a cryptographic key exchange process. Although packets were still visible in the capture files, their contents appeared as encrypted data and could not be read without access to the negotiated session keys.

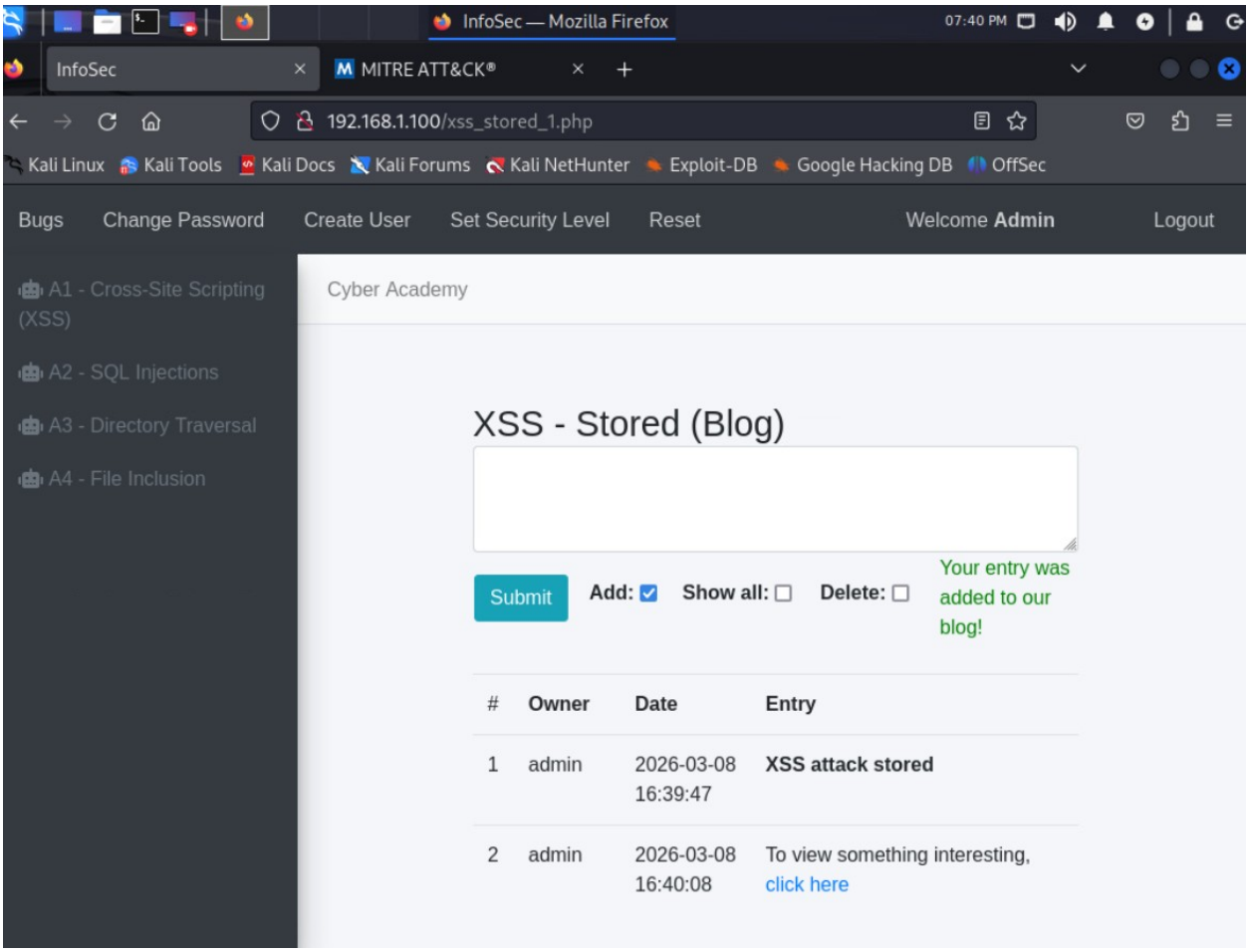
Screenshots

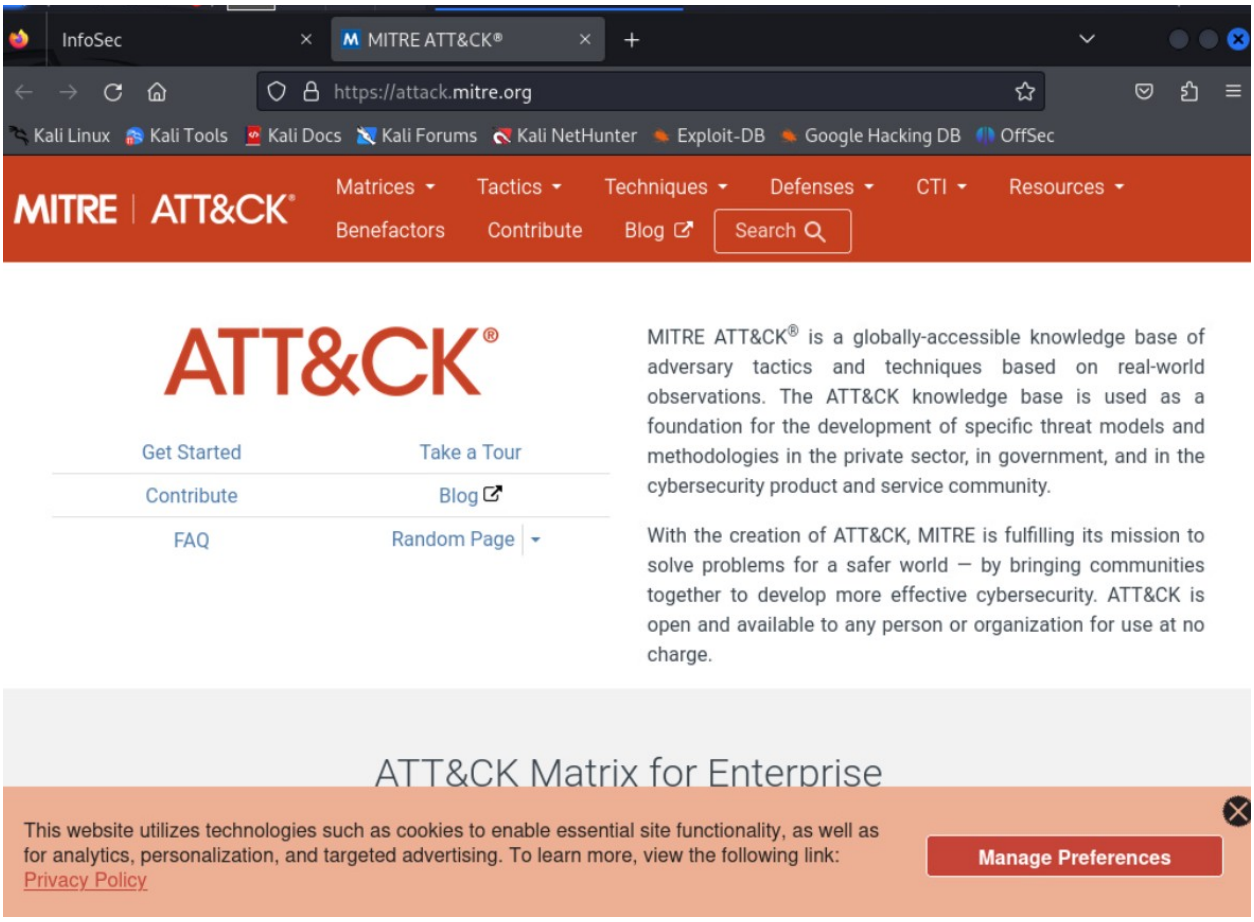


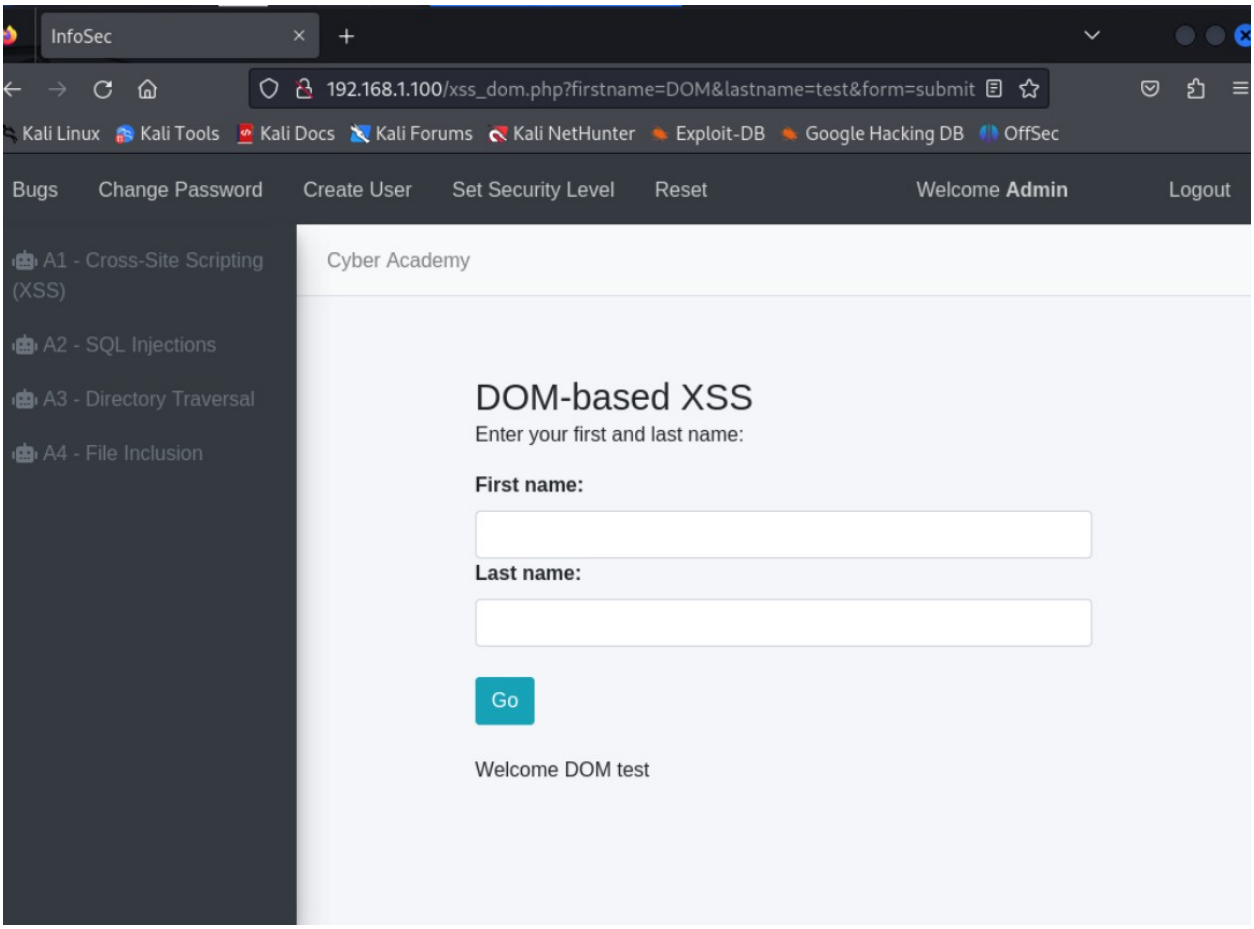

Kali Linux - Student
InfoSec — Mozilla Firefox
07:38 PM
InfoSec
192.168.1.100/xss_get.php?firstname=<b>XSS+attack<%2Fb>&lastname=test&
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
OffSec
Bugs
Change Password
Create User
Set Security Level
Reset
Welcome Admin
Logout
A1 - Cross-Site Scripting (XSS)
A2 - SQL Injections
A3 - Directory Traversal
A4 - File Inclusion
Cyber Academy
XSS - Reflected (GET)
Enter your first and last name:
First name:
Last name:
Go
Welcome XSS attack test

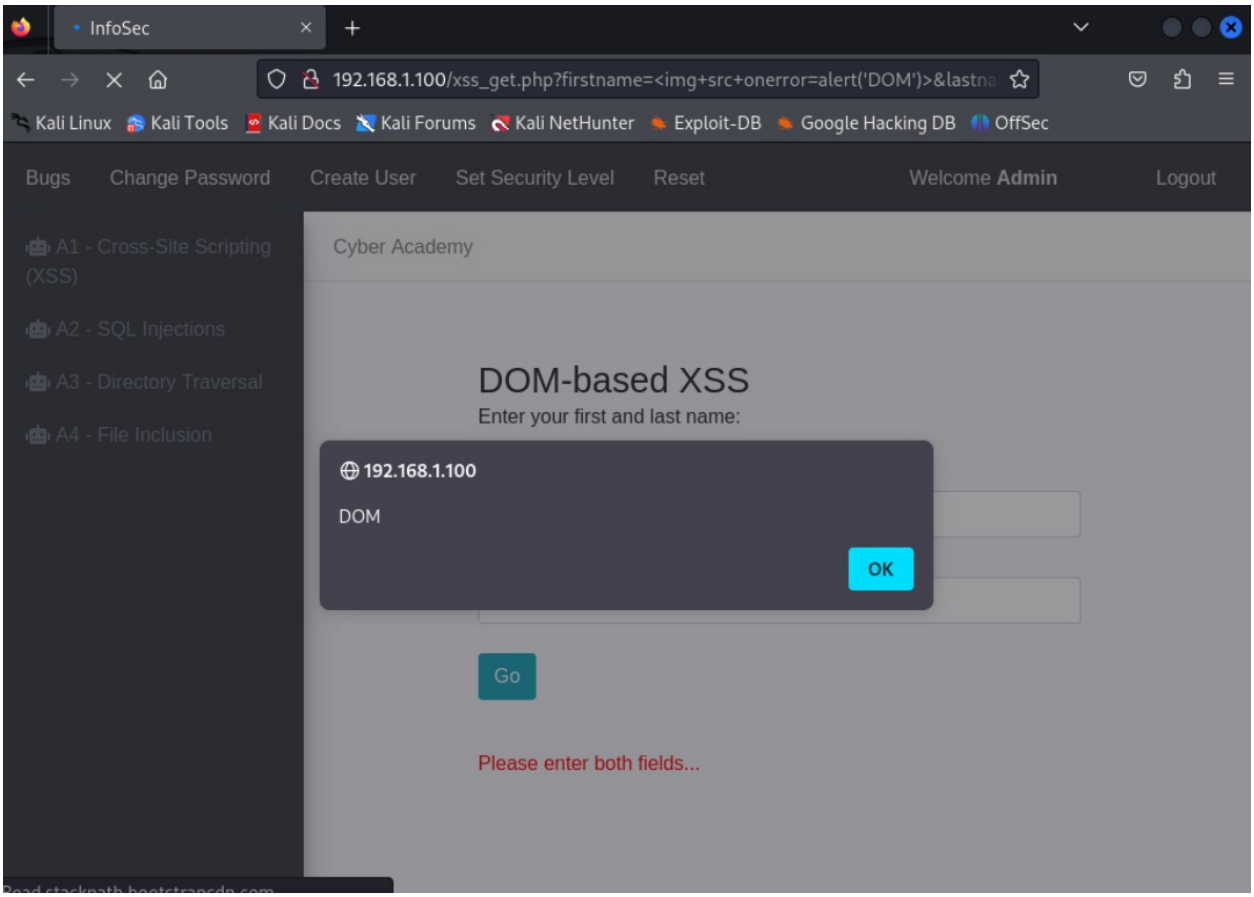

InfoSec — Mozilla Firefox
07:38 PM
InfoSec
192.168.1.100/xss_get.php?firstname=<script>alert('Reflected+XSS')<%2Fscrip
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
OffSec
Bugs
Change Password
Create User
Set Security Level
Reset
Welcome Admin
Logout
A1 - Cross-Site Scripting (XSS)
A2 - SQL Injections
A3 - Directory Traversal
A4 - File Inclusion
Cyber Academy
XSS - Reflected (GET)
Enter your first and last name:
192.168.1.100
Reflected XSS
OK
Go
Welcome XSS attack test
Read stackpath.bootstrapcdn.com

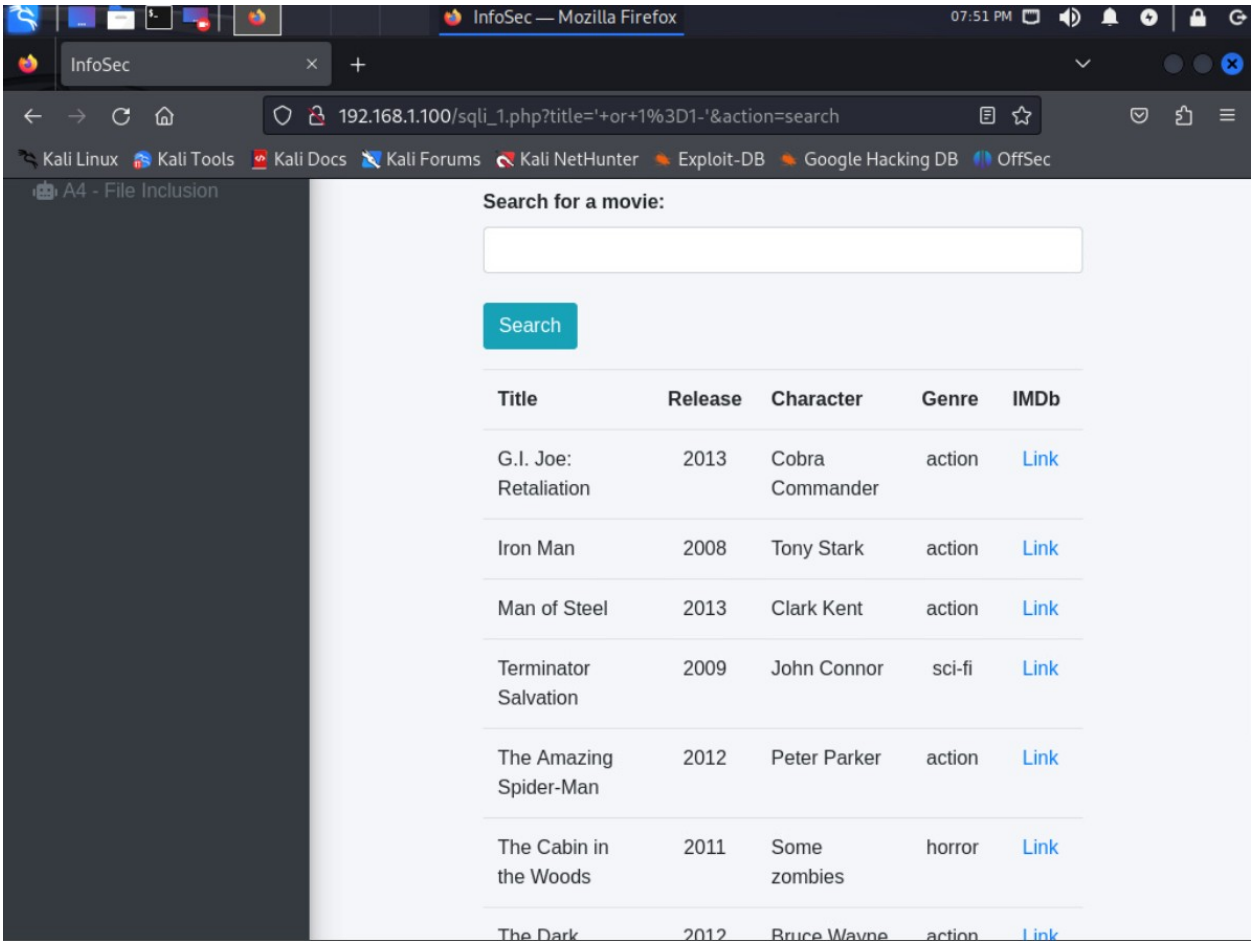

InfoSec — Mozilla Firefox
InfoSec
192.168.1.100/xss_stored_1.php
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
OffSec
Bugs
Change Password
Create User
Set Security Level
Reset
Welcome Admin
Logout
A1 - Cross-Site Scripting (XSS)
A2 - SQL Injections
A3 - Directory Traversal
A4 - File Inclusion
Cyber Academy
XSS - Stored (Blog)
Submit
Add:
Show all:
Delete:
Your entry was added to our blog!
Owner Date Entry
1 admin 2026-03-08 16:39:47 XSS attack stored

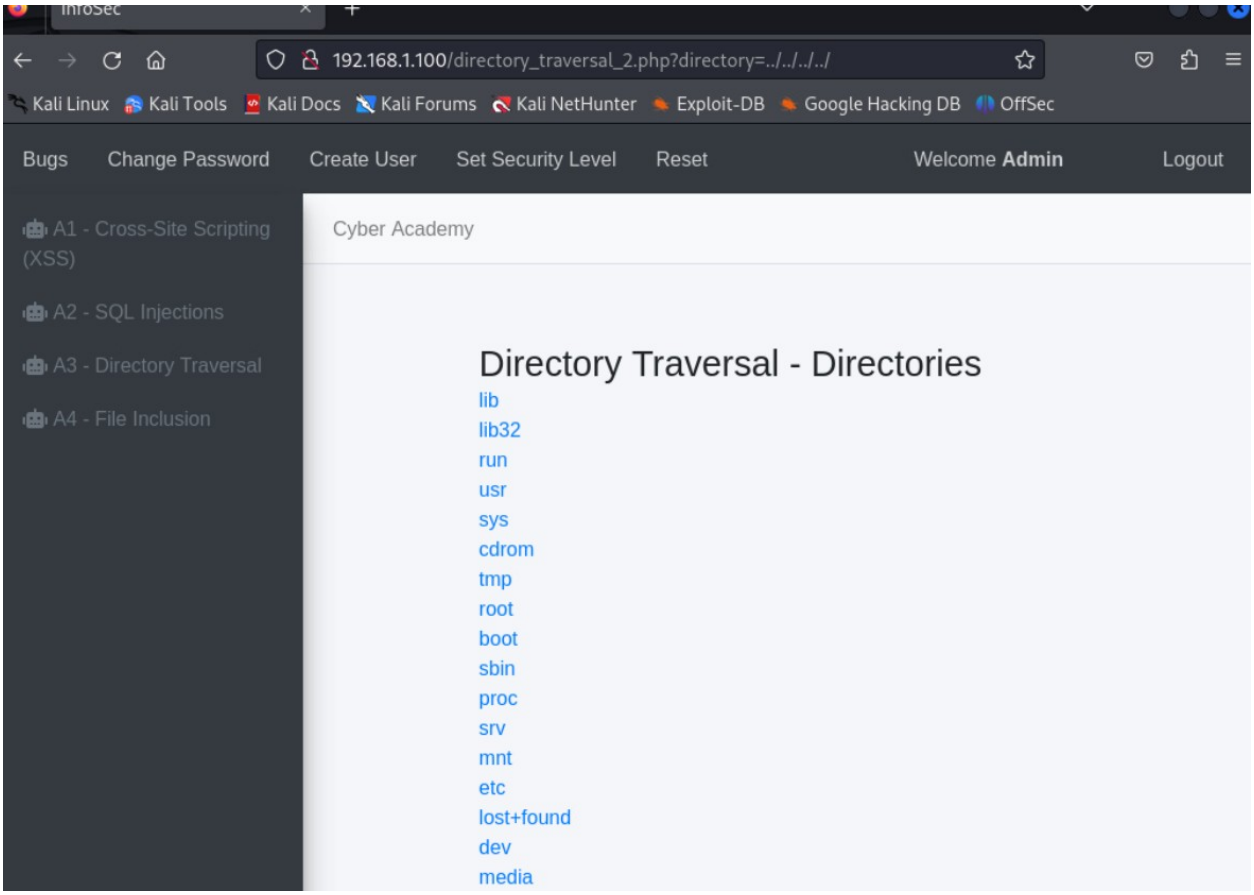

InfoSec — Mozilla Firefox
07:40 PM
InfoSec
MITRE ATT&CK®
192.168.1.100/xss_stored_1.php
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
OffSec
Bugs
Change Password
Create User
Set Security Level
Reset
Welcome Admin
Logout
A1 - Cross-Site Scripting (XSS)
A2 - SQL Injections
A3 - Directory Traversal
A4 - File Inclusion
Cyber Academy
XSS - Stored (Blog)
Submit
Add:
Show all:
Delete:
Your entry was added to our blog!
Owner Date Entry
1 admin 2026-03-08 16:39:47 XSS attack stored
2 admin 2026-03-08 16:40:08 To view something interesting, click here

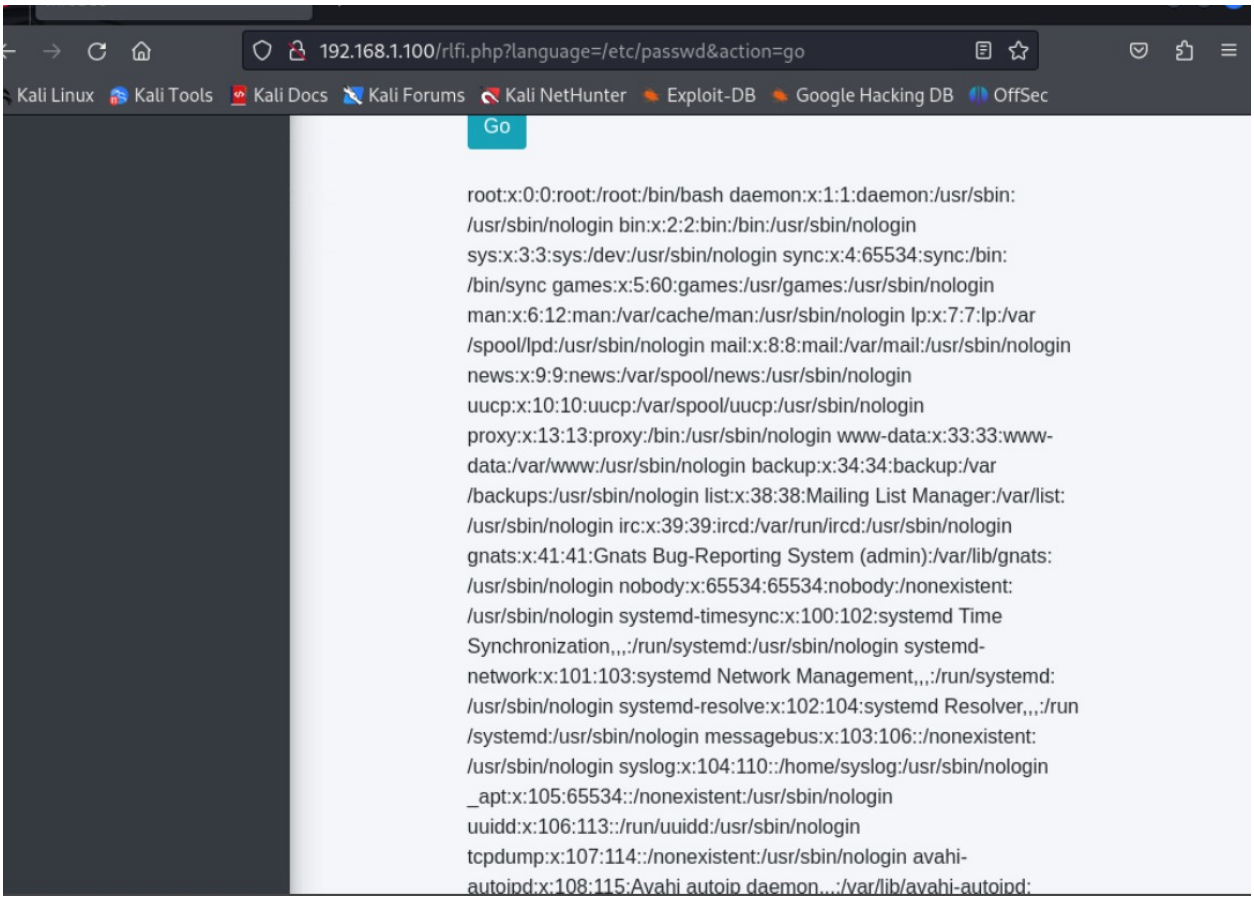

InfoSec
MITRE ATT&CK®
https://attack.mitre.org
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
OffSec
MITRE | ATT&CK®
Matrices
Tactics
Techniques
Defenses
CTI
Resources
Benefactors
Contribute
Blog
Search
ATT&CK®
Get Started
Take a Tour
Contribute
Blog
FAQ
Random Page
MITRE ATT&CK® is a globally-accessible knowledge base of adversary tactics and techniques based on real-world observations. The ATT&CK knowledge base is used as a foundation for the development of specific threat models and methodologies in the private sector, in government, and in the cybersecurity product and service community.
With the creation of ATT&CK, MITRE is fulfilling its mission to solve problems for a safer world — by bringing communities together to develop more effective cybersecurity. ATT&CK is open and available to any person or organization for use at no charge.
ATT&CK Matrix for Enterprise
This website utilizes technologies such as cookies to enable essential site functionality, as well as for analytics, personalization, and targeted advertising. To learn more, view the following link:
Privacy Policy
Manage Preferences

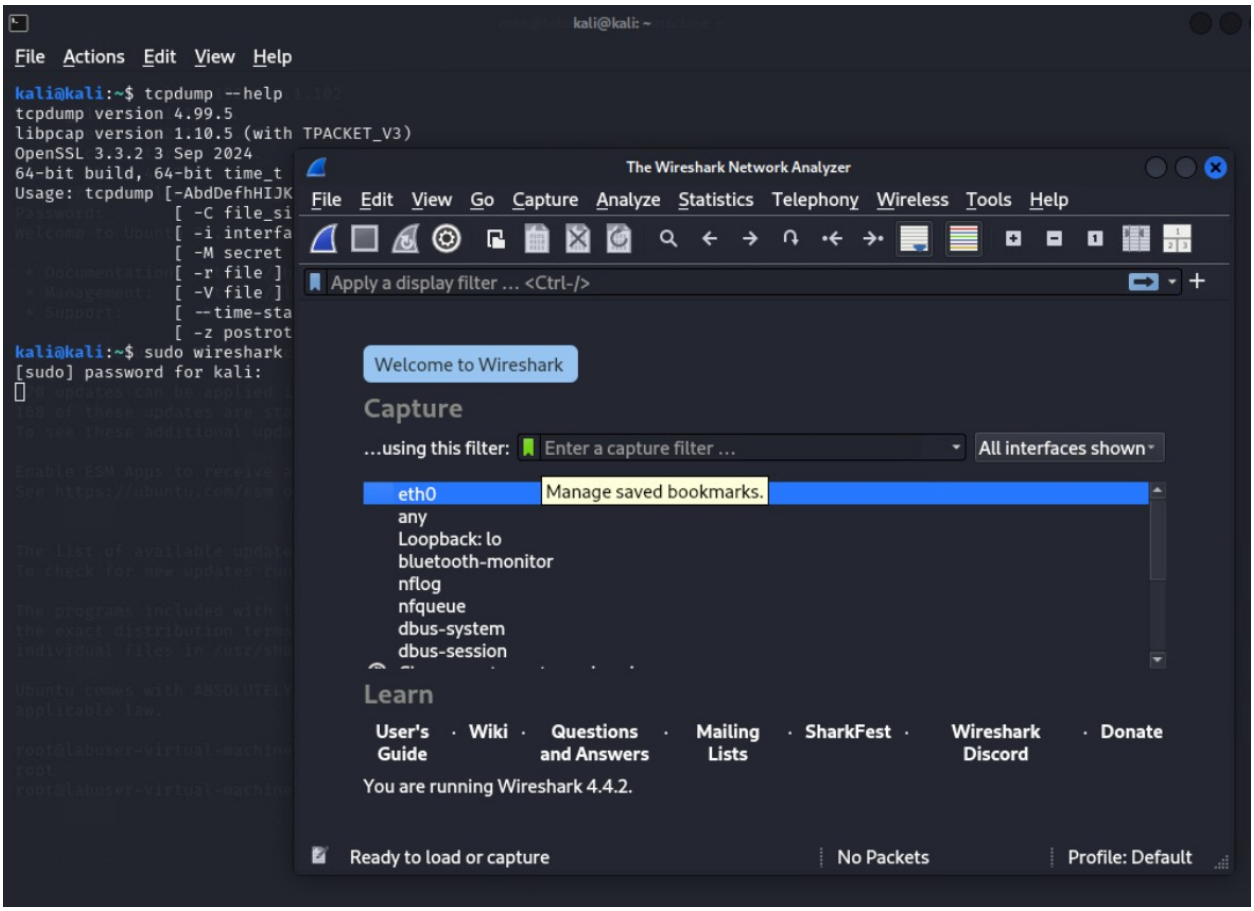

InfoSec
192.168.1.100/xss_dom.php?firstname=DOM&lastname=test&form=submit
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
OffSec
Bugs
Change Password
Create User
Set Security Level
Reset
Welcome Admin
Logout
A1 - Cross-Site Scripting (XSS)
A2 - SQL Injections
A3 - Directory Traversal
A4 - File Inclusion
Cyber Academy
DOM-based XSS
Enter your first and last name:
First name:
Last name:
Go
Welcome DOM test


InfoSec
192.168.1.100/xss_get.php?firstname=<img+src+onerror=alert('DOM')>&lastna
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
OffSec
Bugs
Change Password
Create User
Set Security Level
Reset
Welcome Admin
Logout
A1 - Cross-Site Scripting (XSS)
A2 - SQL Injections
A3 - Directory Traversal
A4 - File Inclusion
Cyber Academy
DOM-based XSS
Enter your first and last name:
192.168.1.100
DOM
OK
Go
Please enter both fields...


InfoSec — Mozilla Firefox
07:51 PM
InfoSec
192.168.1.100/sqli_1.php?title='+or+1%3D1-'&action=search
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
OffSec
A4 - File Inclusion
Search for a movie:
Search
Title
Release
Character
Genre
IMDb
G.I. Joe: Retaliation
2013
Cobra Commander
action
Link
Iron Man
2008
Tony Stark
action
Link
Man of Steel
2013
Clark Kent
action
Link
Terminator Salvation
2009
John Connor
sci-fi
Link
The Amazing Spider-Man
2012
Peter Parker
action
Link
The Cabin in the Woods
2011
Some zombies
horror
Link

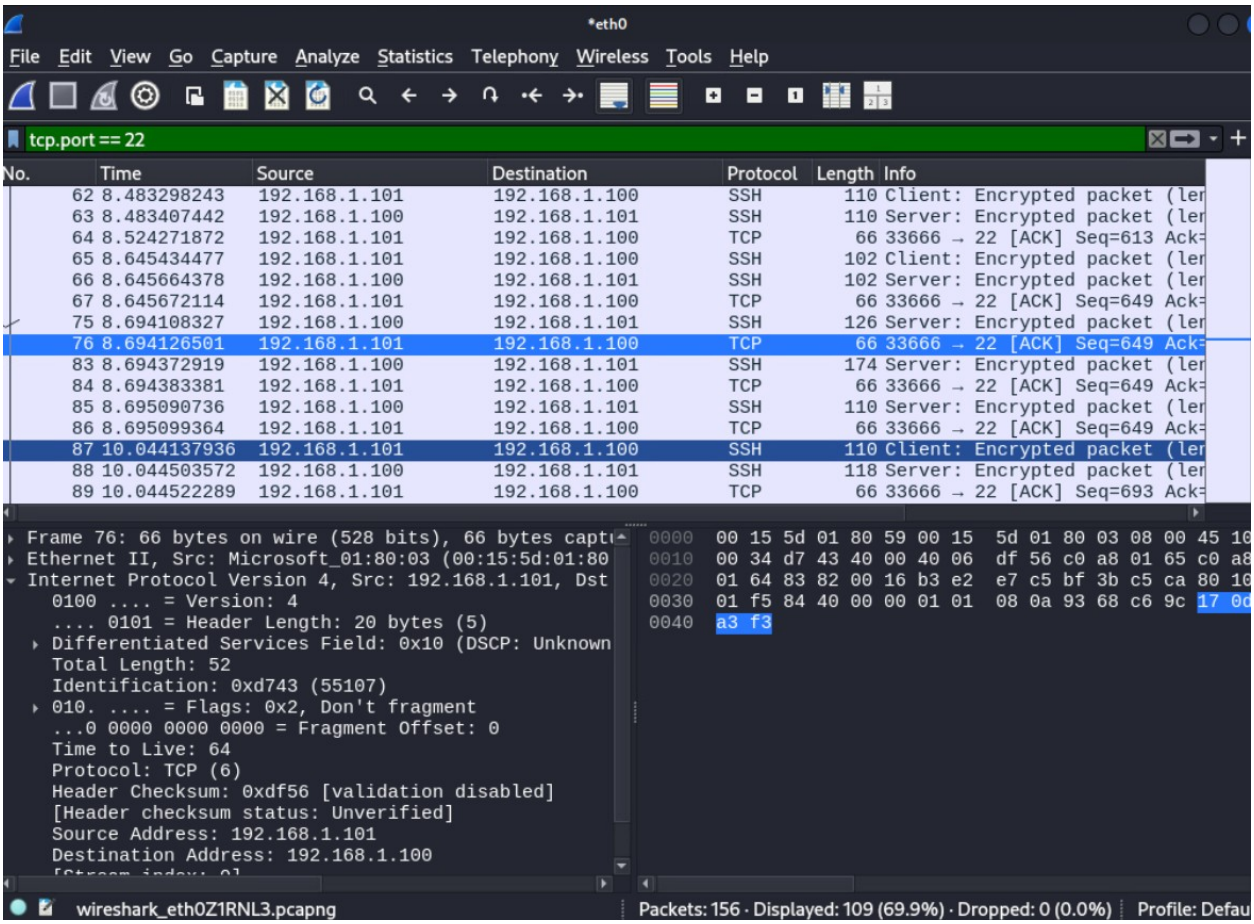

InfoSec
192.168.1.100/directory_traversal_2.php?directory=../../../../
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
OffSec
Bugs
Change Password
Create User
Set Security Level
Reset
Welcome Admin
Logout
A1 - Cross-Site Scripting (XSS)
A2 - SQL Injections
A3 - Directory Traversal
A4 - File Inclusion
Cyber Academy
Directory Traversal - Directories
lib
lib32
run
usr
sys
cdrom
tmp
root
boot
sbin
proc
srv
mnt
etc
lost+found
dev
media

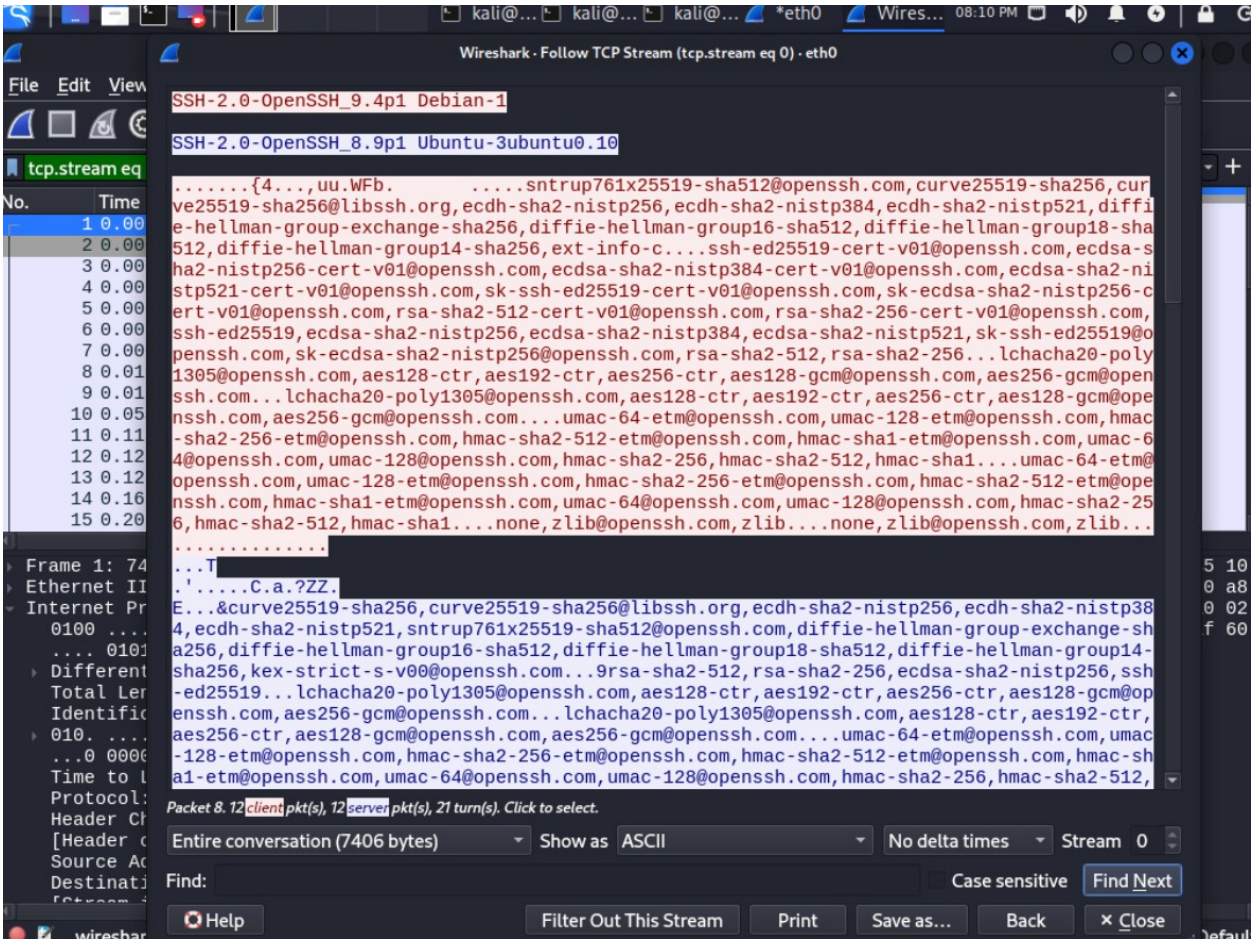

192.168.1.100/rlfi.php?language=/etc/passwd&action=go
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
OffSec
Go
root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:
/usr/sbin/nologin bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin sync:x:4:65534:sync:/bin:
/bin/sync games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:x:7:7:lp:/var
/spool/lpd:/usr/sbin/nologin mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-data:x:33:33:www-
data:/var/www:/usr/sbin/nologin backup:x:34:34:backup:/var
/backups:/usr/sbin/nologin list:x:38:38:Mailing List Manager:/var/list:
/usr/sbin/nologin irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:
/usr/sbin/nologin nobody:x:65534:65534:nobody:/nonexistent:
/usr/sbin/nologin systemd-timesync:x:100:102:systemd Time
Synchronization,,,:/run/systemd:/usr/sbin/nologin systemd-
network:x:101:103:systemd Network Management,,,:/run/systemd:
/usr/sbin/nologin systemd-resolve:x:102:104:systemd Resolver,,,:/run
/systemd:/usr/sbin/nologin messagebus:x:103:106::/nonexistent:
/usr/sbin/nologin syslog:x:104:110::/home/syslog:/usr/sbin/nologin
_apt:x:105:65534::/nonexistent:/usr/sbin/nologin
uuidd:x:106:113::/run/uuidd:/usr/sbin/nologin
tcpdump:x:107:114::/nonexistent:/usr/sbin/nologin avahi-
autoipd:x:108:115:Avahi autoip daemon,,,:/var/lib/avahi-autoipd:


kali@kali: ~
File Actions Edit View Help
kali@kali:~$ tcpdump --help
tcpdump version 4.99.5
libpcap version 1.10.5 (with TPACKET_V3)
OpenSSL 3.3.2 3 Sep 2024
64-bit build, 64-bit time_t
Usage: tcpdump [-AbdDefhHIJK
[-C file_si
[-i interfa
[-M secret
[-r file]
[-V file]
[--time-sta
[-z postrot
kali@kali:~$ sudo wireshark
[sudo] password for kali:
The Wireshark Network Analyzer
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
Apply a display filter ... <Ctrl-/>
Welcome to Wireshark
Capture
...using this filter:
Enter a capture filter ...
All interfaces shown
eth0
Manage saved bookmarks.
any
Loopback: lo
bluetooth-monitor
nflog
nfqueue
dbus-system
dbus-session
Learn
User's Guide · Wiki · Questions and Answers · Mailing Lists · SharkFest · Wireshark Discord · Donate
You are running Wireshark 4.4.2.
Ready to load or capture
No Packets
Profile: Default

```
root@labuser-virtual-machine: ~
File  Actions  Edit  View  Help
kali@kali:~$ telnet 192.168.1.102
Trying 192.168.1.102 ...
Connected to 192.168.1.102.
Escape character is '^]'.
Ubuntu 22.04.4 LTS
labuser-virtual-machine login: root
Password:
Welcome to Ubuntu 22.04.4 LTS (GNU/Linux 6.5.0-41-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

170 updates can be applied immediately.
168 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status


The list of available updates is more than a week old.
To check for new updates run: sudo apt update

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

root@labuser-virtual-machine:~# whoami
root
root@labuser-virtual-machine:~#
```

```
root@labuser-virtual-machine: ~
File  Actions  Edit  View  Help
kali@kali:~$ sudo tcpdump -i eth0 -w ssh_packets.pcapng
[sudo] password for kali:
sudo: a password is required
kali@kali:~$ ssh root@192.168.1.100
The authenticity of host '192.168.1.100 (192.168.1.100)' can't be established.
ED25519 key fingerprint is SHA256:mskd5GrLl0QuY562UpbPJLxCO26mNSFEAn1AcP9zd0Y.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.100' (ED25519) to the list of known hosts.
root@192.168.1.100's password:
Welcome to Ubuntu 22.04.4 LTS (GNU/Linux 6.5.0-41-generic x86_64)
 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

170 updates can be applied immediately.
168 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status


The list of available updates is more than a week old.
To check for new updates run: sudo apt update
The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
root@labuser-virtual-machine:~# whoami
root
root@labuser-virtual-machine:~#
```


*eth0
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
tcp.port == 22
No. Time Source Destination Protocol Length Info
62 8.483298243 192.168.1.101 192.168.1.100 SSH 110 Client: Encrypted packet (len
63 8.483407442 192.168.1.100 192.168.1.101 SSH 110 Server: Encrypted packet (len
64 8.524271872 192.168.1.101 192.168.1.100 TCP 66 33666 → 22 [ACK] Seq=613 Ack=
65 8.645434477 192.168.1.101 192.168.1.100 SSH 102 Client: Encrypted packet (len
66 8.645664378 192.168.1.100 192.168.1.101 SSH 102 Server: Encrypted packet (len
67 8.645672114 192.168.1.101 192.168.1.100 TCP 66 33666 → 22 [ACK] Seq=649 Ack=
75 8.694108327 192.168.1.100 192.168.1.101 SSH 126 Server: Encrypted packet (len
76 8.694126501 192.168.1.101 192.168.1.100 TCP 66 33666 → 22 [ACK] Seq=649 Ack=
83 8.694372919 192.168.1.100 192.168.1.101 SSH 174 Server: Encrypted packet (len
84 8.694383381 192.168.1.101 192.168.1.100 TCP 66 33666 → 22 [ACK] Seq=649 Ack=
85 8.695090736 192.168.1.100 192.168.1.101 SSH 110 Server: Encrypted packet (len
86 8.695099364 192.168.1.101 192.168.1.100 TCP 66 33666 → 22 [ACK] Seq=649 Ack=
87 10.044137936 192.168.1.101 192.168.1.100 SSH 110 Client: Encrypted packet (len
88 10.044503572 192.168.1.100 192.168.1.101 SSH 118 Server: Encrypted packet (len
89 10.044522289 192.168.1.101 192.168.1.100 TCP 66 33666 → 22 [ACK] Seq=693 Ack=
Frame 76: 66 bytes on wire (528 bits), 66 bytes capt
Ethernet II, Src: Microsoft_01:80:03 (00:15:5d:01:80
Internet Protocol Version 4, Src: 192.168.1.101, Dst
0100 .... = Version: 4
.... 0101 = Header Length: 20 bytes (5)
Differentiated Services Field: 0x10 (DSCP: Unknown
Total Length: 52
Identification: 0xd743 (55107)
010. .... = Flags: 0x2, Don't fragment
...0 0000 0000 0000 = Fragment Offset: 0
Time to Live: 64
Protocol: TCP (6)
Header Checksum: 0xdf56 [validation disabled]
[Header checksum status: Unverified]
Source Address: 192.168.1.101
Destination Address: 192.168.1.100
0000 00 15 5d 01 80 59 00 15 5d 01 80 03 08 00 45 10
0010 00 34 d7 43 40 00 40 06 df 56 c0 a8 01 65 c0 a8
0020 01 64 83 82 00 16 b3 e2 e7 c5 bf 3b c5 ca 80 10
0030 01 f5 84 40 00 00 01 01 08 0a 93 68 c6 9c 17 00
0040 a3 f3
wireshark_eth0Z1RNL3.pcapng
Packets: 156 · Displayed: 109 (69.9%) · Dropped: 0 (0.0%)
Profile: Defau



Security+ - Web Vulnerabilities
Lab · 1 hour

Because of the need to be public-facing and the information they provide, websites and web servers are a common target of attacks. The path to exploiting these attacks is most commonly created by logical errors in development or using vulnerable software to aid in building up the website. What adds to the pool of possible weak points is the need to integrate several technologies to create an interactive and responsive user experience, usage of legacy systems and failure to keep up with security patches. All these factors amount to a vast number of threats, all specific to different versions and programming languages.

Security+ - Secure and Insecure Protocols
Lab · 1 hour

Security by design is an approach to software and hardware development that aims to construct systems free of vulnerabilities by implementing best practices and safeguards. However, it is relatively new as a notion, and prior to it, the aim of software developers was more oriented in functionality than security. The same principle can be seen in protocols such as HTTP, FTP, or POP. Because they apply no data encryption, these protocols are often referred to as clear-text protocols. Anyone who is intercepting the traffic between two entities that communicate using clear-text protocols can see the data flowing through the network in plain text. These protocols gave rise to attacks such as Man-in-the-middle (a malicious actor impersonating legitimate users) and sensitive data exposure. To cover the security holes of clear-text protocols, versions that applied encryption to data were developed.

References

National Institute of Standards and Technology (NIST). (2023). Digital Identity Guidelines: Authentication and Lifecycle Management (SP 800-63B). https://pages.nist.gov/800-63-4/sp800-63b.html

National Institute of Standards and Technology (NIST). (2022). Secure Software Development Framework (SSDF) Version 1.1 (SP 800-218). https://doi.org/10.6028/NIST.SP.800-218

Open Web Application Security Project (OWASP). (2023). OWASP Top 10: The Ten Most Critical Web Application Security Risks. https://owasp.org/www-project-top-ten/